ONE-PAGE BRIEF

Post-quantum cryptography review: matrix-js-sdk @ 61b08bd037a3

Client: Matrix.org Foundation — public repository (passive review) · Source: github.com/matrix-org/matrix-js-sdk, commit `61b08bd037a3` · Reviewed: 2026-10-28 18:22 UTC · Risk profile: Security software vendor

POST-QUANTUM MATURITY

Level 0 of 4

no post-quantum cryptography

FINDINGS

0 Critical **2** High **1** Medium **1** Low **1** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Key establishment: 10 + 3 − 8 = 5 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

High QSI-2026-05835	**markdown-it 14.3.2 is affected by GHSA-gfr2-rv44-r23c (CVE-2026-111758)** What to do: Upgrade to a fixed version (14.3.3, 15.0.3).
High QSI-2026-05837	**zod 4.6.5 is affected by GHSA-mrhx-c7xc-m3w5 (CVE-2023-54404)** What to do: Upgrade to a fixed version (4.6.6).
Medium QSI-2026-05834	**Quantum-vulnerable ECDH: channel key exchange (TLS, Noise, handshakes) (1 file(s))** preliminary What to do: Move the handshake to a hybrid key exchange (X25519MLKEM768 in TLS 1.3; a hybrid KEM in Noise-based protocols).
Low QSI-2026-05836	**markdown-it 14.3.2 is affected by GHSA-vfgh-jcmw-g37q (CVE-2026-111766)** What to do: Upgrade to a fixed version (14.3.3, 15.0.3).

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium channel key exchange (TLS, Noise, handshakes)	ECDH	Move the handshake to a hybrid key exchange (X25519MLKEM768 in TLS 1.3; a hybrid KEM in Noise-based protocols)

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 3; each needs checking against the code.

Static review of source code and manifests; files analysed: 240. No requests were sent to the owner's systems.

Full report, content SHA-256: `6b99f797316754f231b4b06db6d193f9d0893a7f657f49253d76cbd060ebaeb3`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.